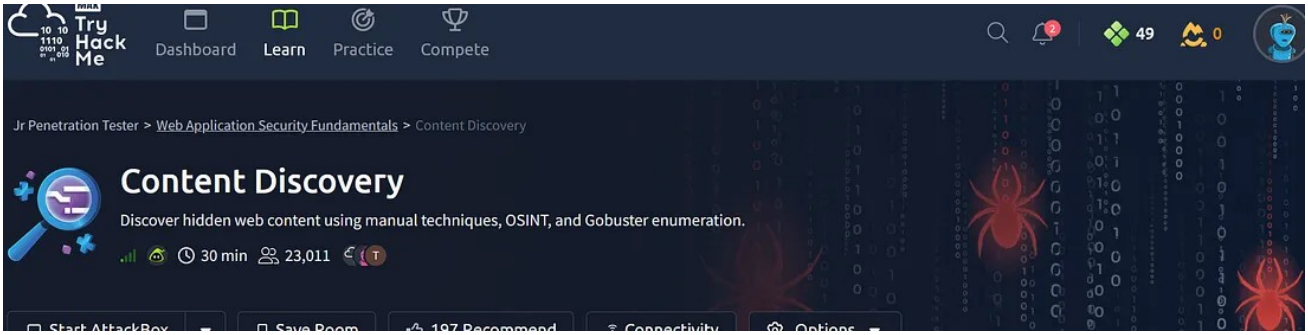
Open in app ↗

Medium

Access to everything. Now 30% off. Upgrade now



Content Discover

Content Discovery “ TRYHACKME WALKTROUGH”

12 min read · Just now

Nuh hozar

Listen Share More

Task 1- Introduction

In web application security, content refers to anything hosted on a web server, such as pages, files, directories, admin portals, configuration files, and backup archives. **Content discovery** is the process of finding content that wasn’t meant to be publicly accessible or isn’t linked anywhere obvious.

This content could be staff portals, older versions of the site, exposed backup files, or administration panels. Finding it is a core part of any web application penetration test.

There are three main approaches to content discovery: manual, automated, and OSINT (Open-Source Intelligence). This room covers all three.

Learning Objectives

By the end of this room, you’ll be able to:

- Manually discover hidden content using robots.txt, sitemap.xml, favicons, HTTP headers, and framework analysis
- Use OSINT tools, including Google dorking, Wappalyzer, the Wayback Machine, GitHub, and S3 bucket enumeration
- Use Gobuster to brute-force directories, subdomains, and virtual hosts
- Apply a structured content discovery methodology in a penetration test

Prerequisites

You should have an understanding of the following rooms before starting:

- HTTP in Detail
- How Websites Work

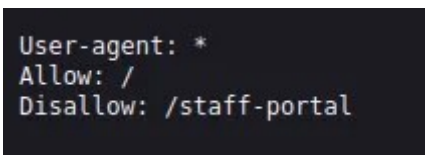
Task 2- Manual Discovery — Common Files

Several files that web servers expose by convention can reveal far more than intended. Checking these manually should be the first step in any content discovery engagement.

robots.txt

The robots.txt file tells search engine crawlers which pages they may index. Site owners often list sensitive directories here to prevent them from appearing in search results, making it a ready-made list of interesting locations for a penetration tester.

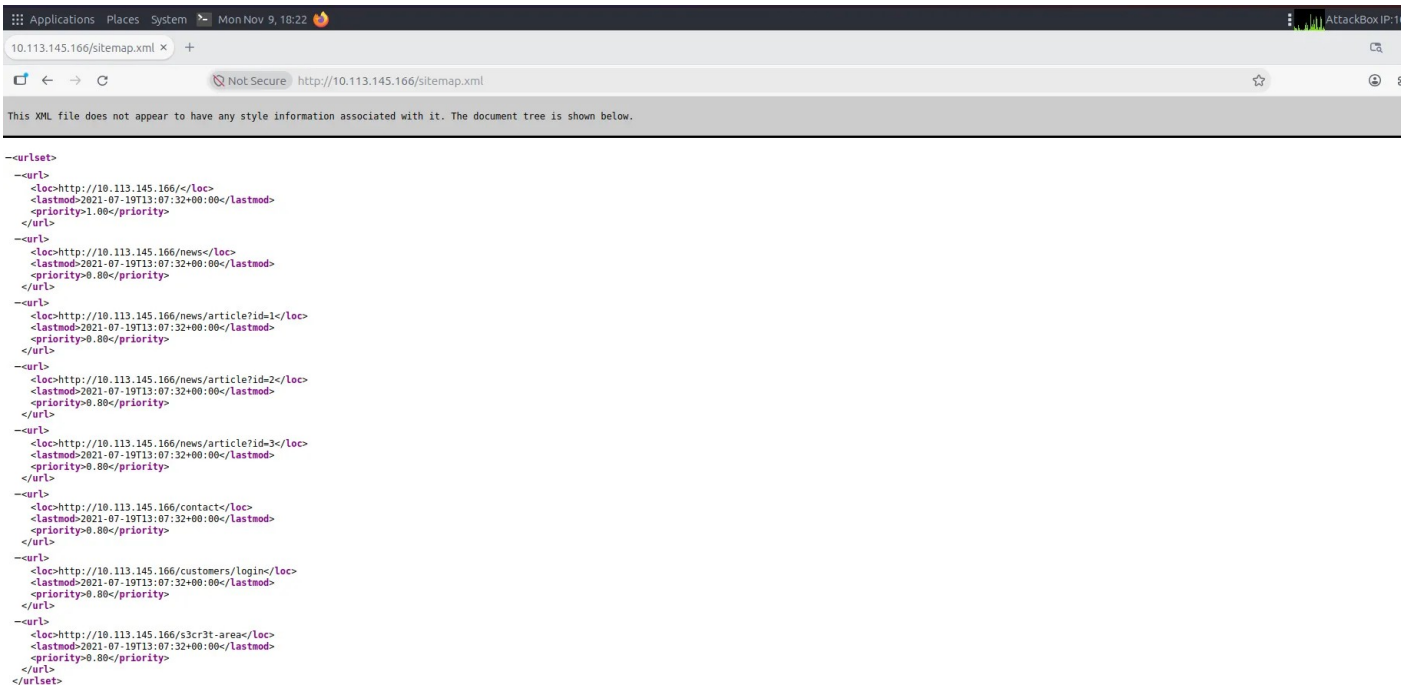
View the robots.txt file on the Acme IT Support website by opening Firefox on the AttackBox and navigating to `http://MACHINE_IP/robots.txt` *(this URL will update 2 minutes after you start the machine)*.



This robots.txt file tells web crawlers (like search engines) how to interact with the site. It allows all bots to access most of the site (`Allow: /`) but asks them not to visit `/staff-portal` . Keep in mind, this is only a guideline for bots, not a security control, so restricted paths may still be accessible if visited directly.

sitemap.xml

Unlike robots.txt (which restricts crawlers), sitemap.xml tells search engines which pages the owner *wants* listed. These files sometimes include staging pages, old content, or URLs that are hard to reach via the normal site. Check it at `http://MACHINE_IP/sitemap.xml` .



As shown in the image, this sitemap lists specific endpoints available on the target application, including standard pages like `/news` , `/contact` , and multiple article IDs (`/news/article?id=1,2,3`). More importantly, it reveals sensitive or interesting paths such as `/customers/login` and `/s3cr3t-area` , which may not be easily discoverable through normal browsing. The presence of parameters like `id=` also hints at potential input points worth testing. This makes the sitemap a valuable source during reconnaissance for mapping the attack surface.

curl https://static-labs.tryhackme.cloud/sites/favicon/images/favicon.ico | md5sum

```
root@ip-10-113-68-4:~# curl https://static-labs.tryhackme.cl
d/sites/favicon/images/favicon.ico | md5sum
  % Total    % Received % Xferd  Average Speed   Time    Tim
    Time  Current
                                 Dload  Upload   Total   Spe
    Left  Speed
  0     0    0     0    0     0      0      0 --:--:-- --:--
100  1406  100  1406    0     0   5896      0 --:--:-- --:--
-  --:--:--  5907
f276b19aabcb4ae8cda4d22625c6735f  -
root@ip-10-113-68-4:~#
```

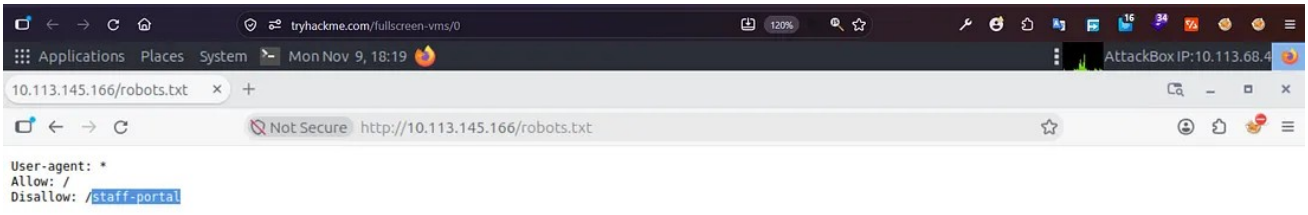
and we can search owasp favicon database

The MD5 hash `f276b19aabcb4ae8cda4d22625c6735f` belonged to the default `favicon.ico` file of the **CGI:IRC** (`cgiirc`) software, according to the OWASP Favicon Database records.



Q 1-What is the directory in robots.txt that isn't allowed to be viewed by web crawlers?

Answer : /staff-portal



Q 2- What is the path of the secret area found in sitemap.xml?

Answer : /s3cr3t-area



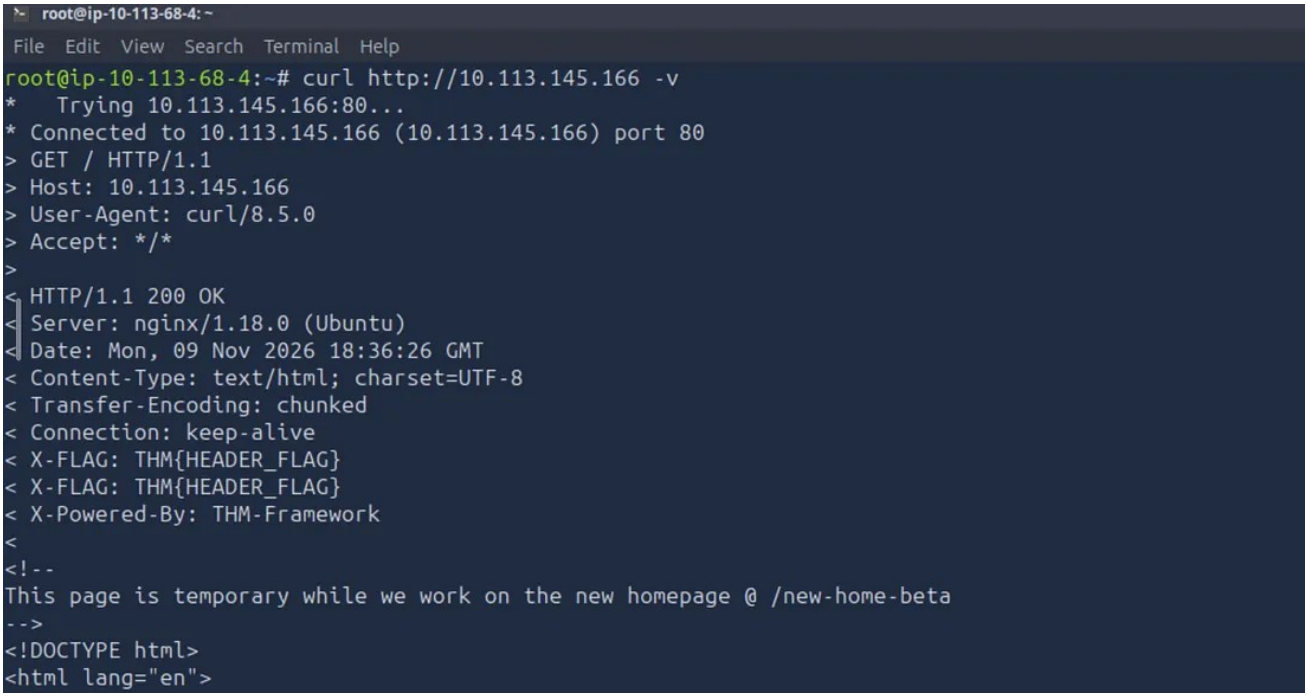
Task 3- Manual Discovery -Headers & Framework Stack

HTTP Headers

When a web server responds to a request, it includes HTTP headers that can reveal useful technical details. Headers like `Server` and `X-Powered-By` often expose the web server software and the language or framework the application runs on.

Run the following command against the Acme IT Support web server. The `-v` flag enables verbose output, which includes the response headers:

Look through the response headers carefully; there may be a custom header containing a flag.



Framework Stack

Once you've identified the framework (from the favicon, headers, or by inspecting the page source for comments and copyright notices), visit the framework's own website to learn more. Documentation pages often describe default directory structures, admin panel paths, and default credentials.



View the Acme IT Support page source at `http://10.113.145.166` , there's a comment at the bottom of every page with a link to the framework's website. Follow that link and check the documentation to find the administration portal path. Access that path on the Acme IT Support site and log in with the default `admin` / `admin` credentials to retrieve the flag.

Q 3 : What is the flag value from the X-FLAG header?

Answer : THM{HEADER_FLAG}

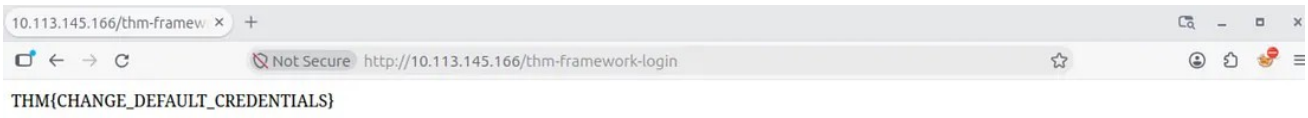


Q 4- What is the flag from the framework's administration portal?

Answer : THM{CHANGE_DEFAULT_CREDENTIALS}

we can use that format

```
http://10.113.145.166/thm-framework-login/
```

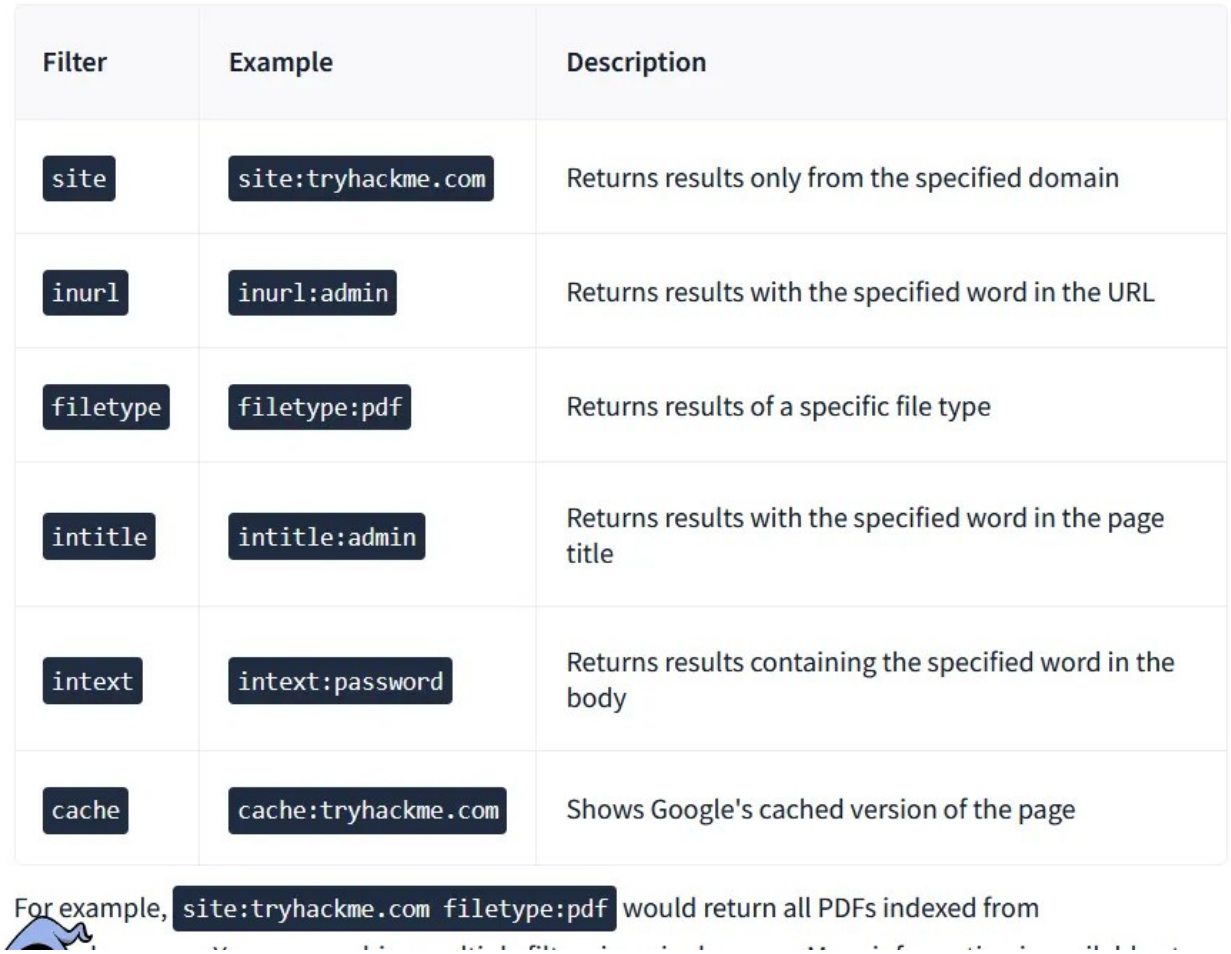


Task 4- OSINT-Search Engines & Web Tools

There are also external resources available that can help in discovering information about your target website; these resources are often referred to as OSINT (Open-Source Intelligence), as they're freely available tools that collect information:

Google Hacking / Dorking

Google's advanced search operators let you filter results in ways that can surface sensitive content indexed from your target. By combining operators, you can find exposed admin panels, leaked documents, and login pages that the site owner never intended to be public.



Filter	Example	Description
site	site:tryhackme.com	Returns results only from the specified domain
inurl	inurl:admin	Returns results with the specified word in the URL
filetype	filetype:pdf	Returns results of a specific file type
intitle	intitle:admin	Returns results with the specified word in the page title
intext	intext:password	Returns results containing the specified word in the body
cache	cache:tryhackme.com	Shows Google's cached version of the page

For example, site:tryhackme.com filetype:pdf would return all PDFs indexed from

For example, `site:tryhackme.com filetype:pdf` would return all PDFs indexed from tryhackme.com. You can combine multiple filters in a single query. More information is available at Wikipedia: Google Hacking.

Wappalyzer

Wappalyzer is a browser extension and online tool that identifies the technologies a website uses, frameworks, CMS platforms, CDNs, analytics tools, payment processors, and more. It can often detect version numbers, which helps when searching for known vulnerabilities. Install it from your browser’s extension store and visit any site to see the tech stack immediately.

Q 5-What Google dork operator limits results to a specific site?

Answer : site:

Q 6- What online tool and browser extension identifies what technologies a website is running?

Answer : Wappalyzer

Task 5- OSINT-Repositories & Archives

Wayback Machine

The Wayback Machine is an archive of the Internet dating back to the late 1990s. Search for a domain, and you’ll see every snapshot captured over time. This is useful for finding pages that have been removed from the live site but may still be accessible: old login forms, forgotten API endpoints, or content that was published briefly before being taken down.

GitHub

Git is a **version control system** that tracks changes to files over time. GitHub is the most widely used cloud-hosted platform for Git repositories. Developers sometimes accidentally commit sensitive data: API keys, credentials, configuration files, and `.env` files, before realising the repository is public.

Search GitHub for the company name or domain you’re targeting. Once you find a relevant repository, look through the commit history, not just the current files. Sensitive data is often removed in a later commit, but remains in the history.

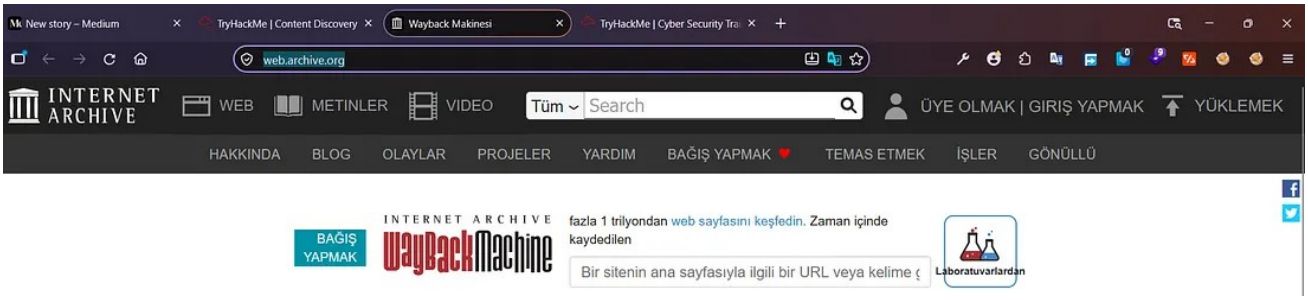
S3 Buckets

Amazon S3 (Simple Storage Service) is a cloud storage platform that many organisations use to host files and static website content. The URL format for an S3 bucket is `https://{name}.s3.amazonaws.com`. Bucket owners set permissions, but misconfigurations are common: a publicly accessible bucket can expose files that were never meant to be seen.

Common naming patterns include `{company}-assets`, `{company}-backup`, `{company}-www`, and `{company}-dev`. Try these patterns against your target's company name. You can also find bucket URLs in the website's page source or in GitHub repositories.

Q 7-What is the website address for the Wayback Machine?

Answer : https://web.archive.org/

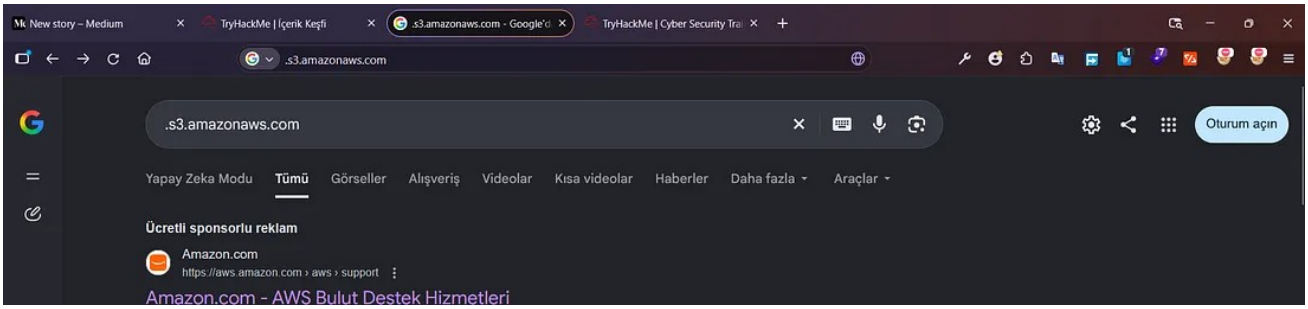


Q 8- What URL format do Amazon S3 buckets end in? (Answer starts with a .)



Subscribe to Pro Writer Tools to remove upgrade prompts from your unlocked stories.

Answer : .s3.amazonaws.com



.s3.amazonaws.com

Task 6- Automated Discovery-Gobuster Fundamentals

Manual and OSINT techniques can only take you so far. Automated discovery uses tools to rapidly send hundreds or thousands of requests to a web server to check whether directories, files, or other resources exist. This process relies on **wordlists,** text files containing commonly used directory names, file names, and paths.

Gobuster

Gobuster is an open-source enumeration tool written in Go. It supports multiple modes: directory/file enumeration (`dir`), DNS subdomain enumeration (`dns`), and virtual host enumeration (`vhost`). It's pre-installed on the AttackBox and included by default in Kali Linux.

Run `gobuster --help` to see the available commands and global flags:

Flag	Description
`-t` / `--threads`	Number of concurrent threads (default: 10). Increase for faster scans.
`-w` / `--wordlist`	Path to the wordlist file. Required for all modes.
`-o` / `--output`	Write results to a file instead of stdout.
`--delay`	Wait time between requests: useful against rate-limited servers.

Wordlists

Wordlists

A good wordlist is critical. SecLists is the most widely used collection and is pre-installed on the AttackBox at `/usr/share/wordlists/SecLists/` . For directory enumeration, `Discovery/Web-Content/common.txt` and `Discovery/Web-Content/directory-list-2.3-medium.txt` cover most scenarios.

dir Mode

The `dir` mode brute-forces directories and files on a web server. The basic syntax

is:

```
gobuster dir -u "http://10.113.145.166" -w /path/to/wordlist
```

The `-u` flag specifies the target URL that Gobuster will run its discovery against. The `-w` flag specifies the wordlist file; a list of directory and file names Gobuster will try against the target one by one. Both `-u` and `-w` are required for Gobuster to run; omitting either will result in an error.

Some additional useful flags for `dir` mode:

Flag	Description
`-x` / `--extensions`	File extensions to search for (e.g., `-x .php,.txt,.js`)
`-r` / `--followredirect`	Follow HTTP redirects
`-k` / `--no-tls-validation`	Skip TLS certificate verification (useful in lab environments)
`-s` / `--status-codes`	Only show specific status codes (e.g., `-s 200,301`)

Run the following command against the Acme IT Support web server and review the results:

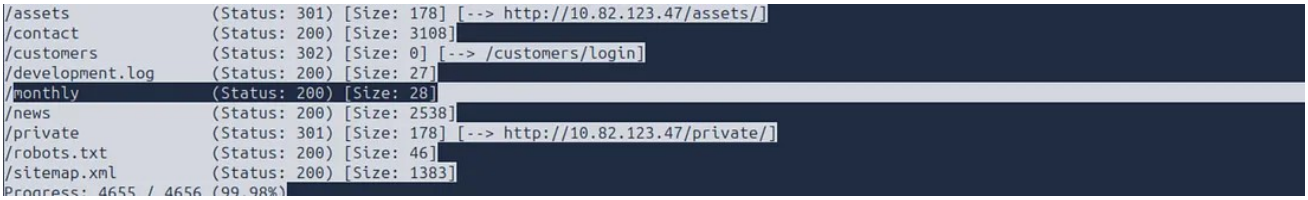
```
gobuster dir -u http://10.113.145.166 -w /usr/share/wordlists/SecLists/Disco
```



As shown in the above output, the Gobuster scan has discovered several accessible directories and files on the target web application. It reveals common pages like `/contact` and `/news`, along with interesting endpoints such as `/customers` (which redirects to a login page) and `/development.log`, which may contain sensitive information. Additionally, directories such as `/private` and `/assets` were found, along with files such as robots.txt and sitemap.xml, which can further aid reconnaissance. This output helps map the application structure and identify potential entry points for further testing.

Q 9- What is the name of the directory beginning with `/mo` that was discovered?

Answer : /monthly



Q 10-What is the name of the log file that was discovered?

Answer : /development.log



Task 7- Automated Discovery Subdomains & Virtual Hosts

The next mode we'll focus on is the `dns` and `vhost` mode. The `dns` mode allows Gobuster to brute-force subdomains. During a penetration test, checking the subdomains of your target's top domain is essential. Just because something is patched in the regular domain, it doesn't mean it is also patched in the subdomain. An opportunity to exploit a vulnerability in one of these subdomains may exist.

For example, if TryHackMe owns `tryhackme.thm` and `mobile.tryhackme.thm`, there may be a vulnerability in `mobile.tryhackme.thm` that is not present in `tryhackme.thm`. That is why it is important to search for subdomains as well!

Subdomains vs Virtual Hosts

It's important to understand the difference between these two concepts before using Gobuster to enumerate them:

- A **subdomain** is resolved through DNS. For example, `blog.example.thm` is a DNS record that points to an IP address.
- A **virtual host (vhost)** is resolved by the web server. Multiple sites can run on the same IP address, with the server using the `Host:` HTTP header to decide which site to serve.

As mentioned, Gobuster has separate modes for each: `dns` for subdomains and `vhost` for virtual hosts.

Preparing the Environment

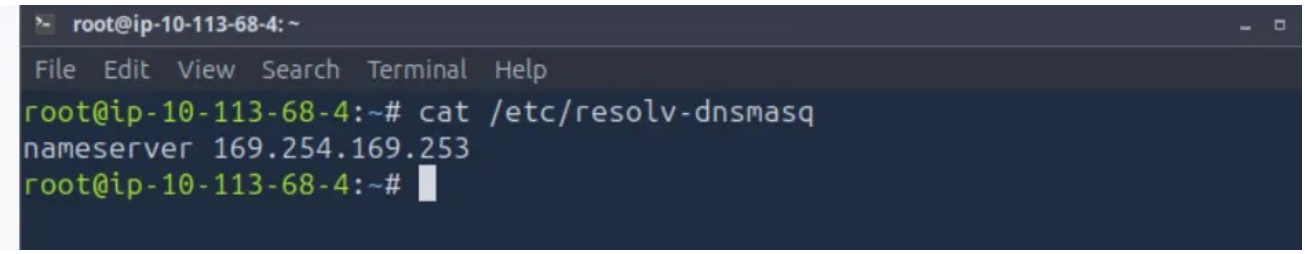
We are going to work in a local network with a DNS server on the web server. To ensure we can resolve the domains used throughout this room, you need to change the `/etc/resolv-dnsmasq` file:

- Open up a terminal on the AttackBox and enter the command: `sudo nano /etc/resolv-dnsmasq`.
- Insert `nameserver 10.113.145.166` as the first line.
- Save the file by pressing `CTRL+O`, followed by pressing `ENTER`, and then exit

the editor by pressing `CTRL+X`.

- Enter the command `/etc/init.d/dnsmasq restart` to restart the Dnsmasq service.

The file should look something like this:



Updating the Host File

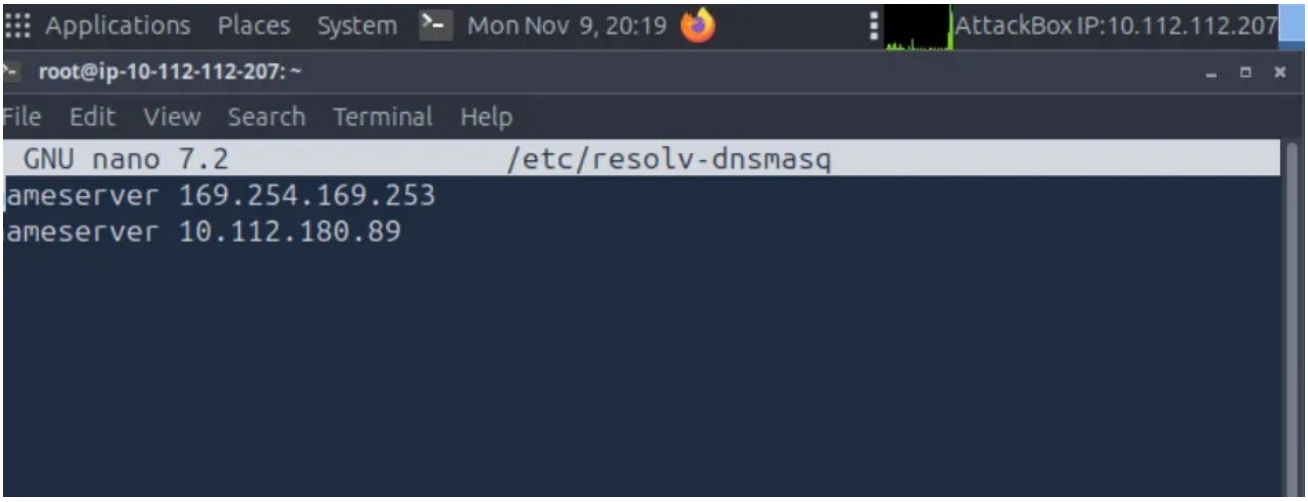
To ensure the domain used in this room resolves correctly, we need to manually map it to the target IP using the `/etc/hosts` file:

- Open a terminal on the AttackBox and run: `sudo nano /etc/hosts`.
- Add the following line at the end of the file: `10.113.145.166 example.thm`.
- Save the file by pressing `CTRL+O`, then `ENTER`, and exit using `CTRL+X`.
- You can verify the change by running: `ping example.thm`.

The file should look something like this:

we use that command

`sudo nano /etc/hosts`.

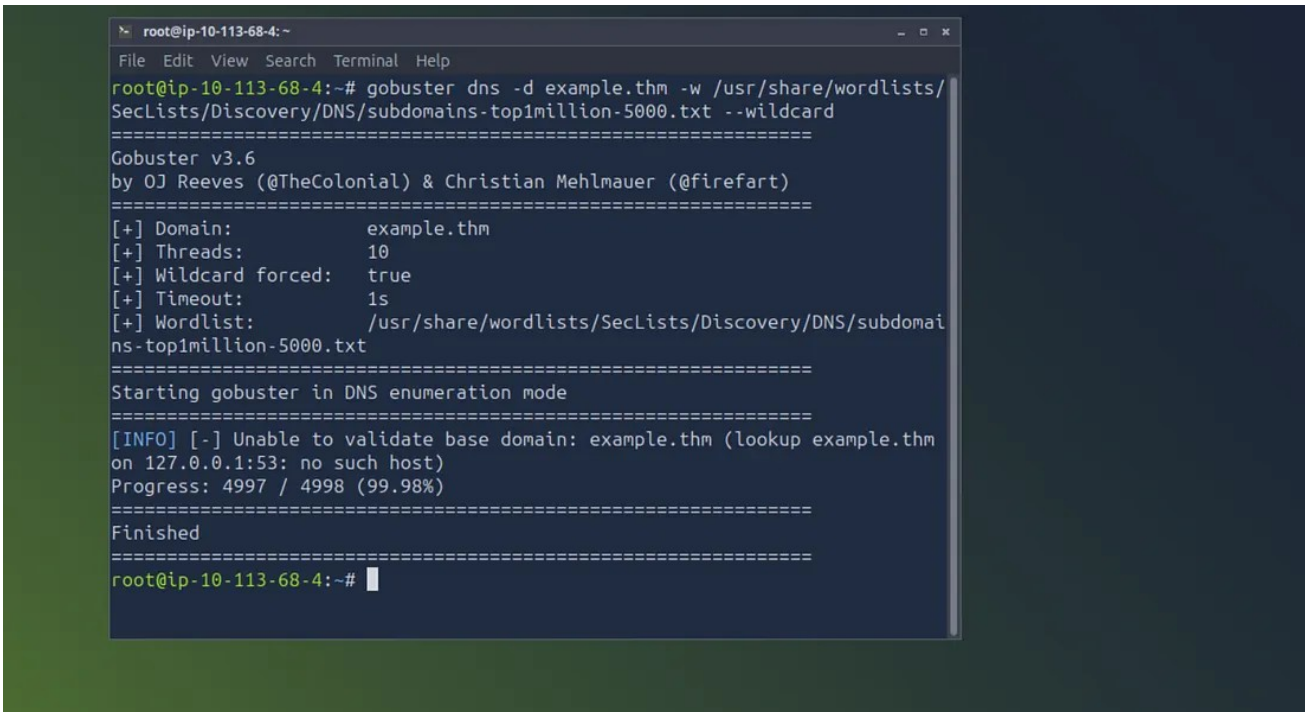


dns Mode

The `dns` mode performs DNS lookups using wordlist entries as subdomain candidates. The required flags are `-d` (domain) and `-w` (wordlist). The `--wildcard` option in Gobuster is used to force enumeration even when wildcard DNS is detected, allowing results to be returned despite potential false positives.

In the AttackBox, enter the following command:

```
gobuster dns -d example.thm -w /usr/share/wordlists/SecLists/Discovery/DNS/su
```



Some useful flags for `dns` mode are:

Flag	Description
`-d` / `--domain`	The target domain to enumerate
`-i` / `--show-ips`	Show the IP addresses that subdomains resolve to
`-r` / `--resolver`	Use a custom DNS server for lookups

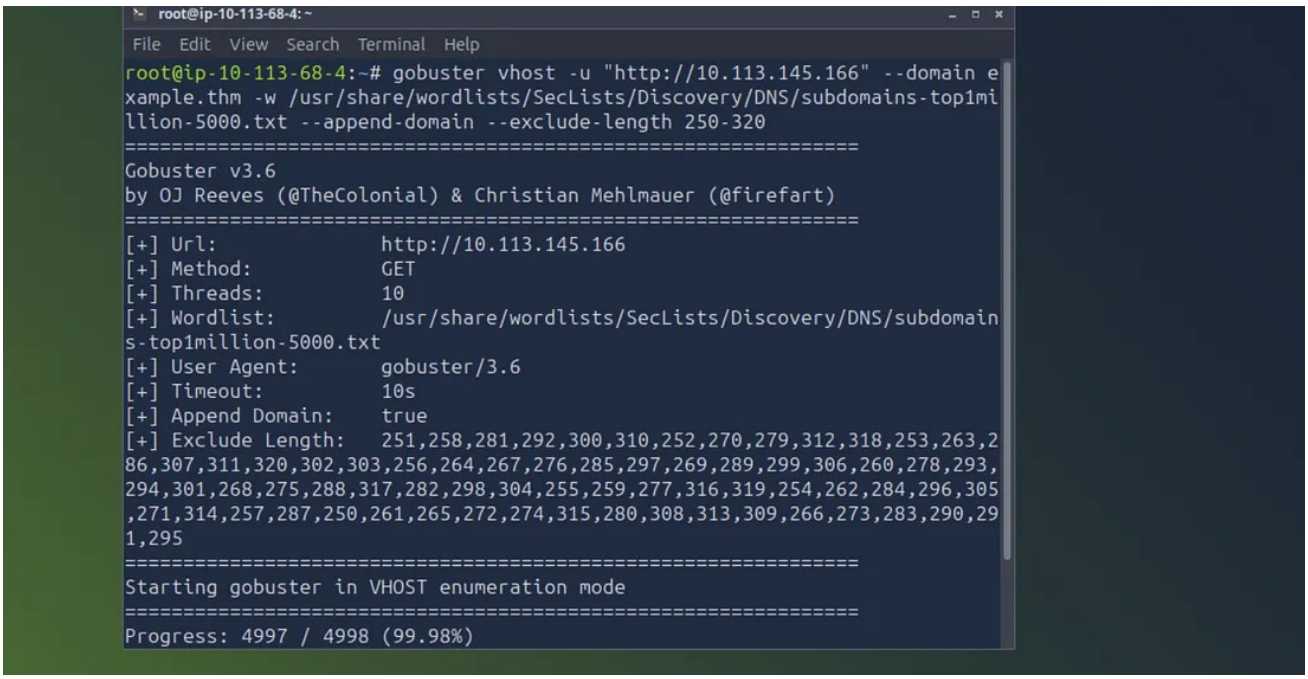
vhost Mode

The `vhost` mode doesn't use DNS. Instead, it sends HTTP requests to the target IP, cycling through wordlist entries as the `Host:` header value. This finds virtual hosts that aren't registered in public DNS.

Run the `vhost` scan with the following commands. The `--append-domain` flag tells Gobuster to combine each wordlist entry with the domain, and `--exclude-length` filters out false positives that share a common response size:

we use that command

```
gobuster vhost -u "http://10.113.145.166" --domain example.thm -w /usr/share
```



Review the results and identify the virtual hosts responding with a `200 OK` status. Access each one in your browser to explore what's hosted there.

As shown in the above output, a virtual host enumeration was performed using Gobuster to identify hidden subdomains associated with the target. The scan used a large wordlist and filtered out common response lengths to reduce noise, focusing only on meaningful results. However, no valid virtual hosts were discovered during the scan, indicating that there are likely no additional subdomains configured for this application. This suggests that further testing should focus on the main domain and the identified directories.

Q 11-Apart from `dns` and `-w`, which shorthand flag is required for dns mode?

Answer : -d

Q 12-How many virtual hosts on `acmeitsupport.thm` respond with status code 200?

Answer : 3

Task 8- Conclusion

Content discovery is one of the most important phases of web application reconnaissance. The techniques in this room work together: manual checks surface quick wins, OSINT finds information the target has already shared publicly, and automated tools cover the breadth that neither approach can do alone.

Here’s a quick recap of what was covered:

Method	Techniques
Manual	robots.txt, sitemap.xml, favicon fingerprinting, HTTP headers, framework stack
OSINT	Google dorking, Wappalyzer, Wayback Machine, GitHub, S3 buckets
Automated	Gobuster dir, dns, and vhost modes

A good content discovery workflow runs all three methods against a target before moving to exploitation. The directories and files you find here feed directly into later stages of a penetration test.

happy hacking

nuh hozar block sayfası

https://nuhhozar.blogspot.com

nuhhozar.blogspot.com

Nuh hozar - Medium

Read writing from Nuh hozar on Medium. Whatever is in the name of goodness and beauty, those who know us know, those...

nuhhozar.medium.com

NuhHozar - Overview

Only Curiosity for cyber world. NuhHozar has 37 repositories available. Follow their code on GitHub.

github.com

Content Discover +



Follow

Written by Nuh hozar

8 followers · 13 following

Whatever is in the name of goodness and beauty, those who know us know, those who don't know know as well as themselves.!!